

funbox 3

▼ 1-flag

cf63f8f7d8f6a4a7157365c30bc86d5b

▼ root flag

cf63f8f7d8f6a4a7157365c30bc86d5b

ip adress : 10.13.0.237

OS : linux

Penetratsion test hisoboti (Recon / Enumeration)

1) Qisqa xulosa (Executive Summary)

Ushbu ishda lokal tarmoq ichida nishon host(lar)ni aniqlash va tanlangan nishon tizimga nisbatan port/servislarni tekshirish (recon/enumeration) amalga oshirildi. ARP asosidagi skan yordamida tarmoqdagi faol IP manzillar topildi va ulardan biri — **10.13.0.237** nishon sifatida ajratib olindi. Nmap skani natijasida nishonda **FTP (21)**, **SSH (22)** va **HTTP (80)** portlari ochiq ekani aniqlanib, servis versiyalari va ayrim xavfli konfiguratsiyalar (masalan, **Anonymous FTP login yoqilgan**) qayd etildi. Bu topilmalar keyingi bosqichlarda tizimga kirish (initial access) va zaifliklarni tekshirish uchun asos bo'lib xizmat qiladi.

2) Muhit va doira (Scope & Environment)

- **Test muhiti (attacker):** Linux (terminal prompt: `umar@umar`)
- **Attacker IP:** `10.13.1.125` (arp-scan chiqishida ko'rindi)
- **Nishon (target) IP:** `10.13.0.237`
- **Tarmoq turi:** lokal tarmoq (Layer 2 ARP orqali ko'rish mumkin)

3) Bajarilgan ishlar (bosqichma-bosqich)

3.1 `sudo arp-scan -l`

Maqsad: lokal tarmoqda faol hostlarni aniqlash (IP ↔ MAC). ARP skan LAN'da ishonchli, chunki ba'zi hostlar ping'ga javob bermasa ham ARP orqali ko'rinadi.

Natija: tarmoqdagi hostlar ro'yxati chiqdi va nishon sifatida `10.13.0.237` (MAC: `08:00:27:c5:72:c6`) aniqlandi.

Eslatma: vendor fayllarga ruxsat bo'lmagani uchun MAC vendor "Unknown" chiqdi; bu skan natijasiga jiddiy ta'sir qilmaydi.

3.2 `nmap -p- 10.13.0.237 -T4 -A`

Maqsad: nishondagi barcha TCP portlarni tekshirish (`-p-`) va servis/versiyalarni aniqlash (`-A`). `-T4` skan tezligini oshirish uchun ishlatildi.

Natija (ochiq portlar):

- **21/tcp — FTP:** `vsftpd 3.0.2`
 - Anonymous login yoqilgan: `ftp-anon: Anonymous FTP login allowed (230)`
 - FTP ichida fayl bor: `file.txt` (25 bayt)
- **22/tcp — SSH:** `OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13`
- **80/tcp — HTTP:** `Apache 2.4.7 (Ubuntu)`
 - Sahifa title: **Car Racing**

4) Topilmalar (Findings) — qisqa

1. **Anonymous FTP login yoqilgan** — ma'lumot oshkor bo'lishi ehtimoli. (*Severity: Medium*)
2. **FTP'da `file.txt` mavjud** — ichida credential/hint bo'lishi mumkin. (*Severity: Medium*)
3. **HTTP servis mavjud (Apache 2.4.7)** — web orqali zaiflik bo'lishi mumkin. (*Severity: Medium/High — tekshiruvga bog'liq*)
4. **SSH ochiq** — credential topilsa masofaviy kirish mumkin. (*Severity: Medium*)

5) Keyingi qadamlar (reja)

- FTP'ga kirib `file.txt` ni yuklab olish va tahlil qilish.

- Web enumeration: `robots.txt`, kataloglar (gobuster/dirb), texnologiyalar (whatweb) va h.k.
- Agar credential topilsa, SSH orqali kirishni sinash (ruxsat doirasida).

Web Enumeration (robots.txt va yashirin fayl)

6) robots.txt tekshiruvi

Maqsad: `robots.txt` fayli odatda qidiruv botlariga yo'l-yo'riq beradi, lekin amalda u ba'zan **yashirin kataloglar yoki fayllarni** "tasodifan" oshkor qilib qo'yadi. Shu sababli web enumeration bosqichida birinchi tekshiriladigan joylardan biri hisoblanadi.

Amal: brauzer orqali quyidagi manzil ochildi:

- `http://10.13.0.237/robots.txt`

Natija: `robots.txt` ichida quyidagi fayl nomi ko'rsatildi:

- `HOW TO PLAY.md`

7) Aniqlangan faylni ochish (HOW TO PLAY.md)

Maqsad: `robots.txt` dan chiqqan fayl/katalogni tekshirish — ba'zan u yerda **hint, credential, foydalanuvchi nomi** yoki konfiguratsiya bo'yicha ma'lumotlar bo'ladi.

Amal: aniqlangan fayl nomi IP yoniga yozilib URL ko'rinishida tekshirildi:

- `http://10.13.0.237/HOW%20TO%20PLAY.md`

Natija: sahifa matnining eng past qismida quyidagi ma'lumot topildi:

- **User: alice**

Xulosa: `robots.txt` orqali oshkor bo'lgan `.md` fayl ichidan **foydalanuvchi nomi (alice)** aniqlandi. Bu ma'lumot keyingi bosqichlarda (masalan, SSH yoki boshqa login joylarida) credential topilganda yoki bruteforce ruxsat etilgan holatlarda foydali bo'lishi mumkin.

FTP Enumeration (Anonymous login va file.txt tahlili)

8) FTP xizmatini tekshirish va anonymous orqali kirish

Maqsad: Nmap natijasida FTP (21-port) ochiq va **anonymous login yoqilganligi** aniqlangani sababli, FTP'ga kirib ichidagi fayllarni ko'rish va ehtimoliy "hint/credential"larni topish.

Amal: FTP xizmatiga anonymous foydalanuvchi bilan ulanildi va katalog ko'rildi:

- `ftp 10.13.0.237`
- Username: `Anonymous`
- `ls`

Natija: FTP server ichida `file.txt` fayli mavjudligi tasdiqlandi.

9) file.txt ni yuklab olish va tarkibini ko'rish

Maqsad: FTP ichidagi faylni lokal kompyuterga ko'chirib, ichidagi ma'lumotni tahlil qilish (ko'pincha bunday fayllarda parol, token yoki keyingi yo'riqnoma bo'ladi).

Amal:

- `get file.txt`
- lokalda tekshirish: `cat file.txt`

Natija: `file.txt` tarkibi Base64 formatiga o'xshash ko'rindi (kodlangan matn).

10) Base64 decode orqali ehtimoliy parolni aniqlash

Maqsad: Base64 ko'rinishidagi qiymatni decode qilib, asl matnni olish va uni keyingi autentifikatsiya bosqichida ishlatish.

Amal: qiymat bir necha marta Base64 decode qilindi (layered encoding bo'lishi mumkin).

Natija: decode natijasida quyidagi qiymat olindi:

- `noway_bro`

Xulosa: Topilgan `noway_bro` qiymati **alice** foydalanuvchisi uchun ehtimoliy parol bo'lishi mumkin. Keyingi bosqichda bu qiymat SSH login (22-port) yoki web login

mavjud bo'lsa o'sha joylarda tekshiriladi (ruxsat doirasida).

SSH orqali kirish (alice) va local flagni olish

11) SSH autentifikatsiya (Topilgan credentialni tekshirish)

Maqsad: Oldingi bosqichlarda aniqlangan `alice` foydalanuvchi nomi hamda `noway_bro` ehtimoliy parolini SSH xizmatida sinab ko'rish. SSH muvaffaqiyatli bo'lsa, bu nishonga **initial access** (foothold) olinganini bildiradi.

Amal: SSH orqali ulanildi:

- `ssh alice@10.13.0.237`

Birinchi ulanishda host key tasdiqlandi (`yes`) va so'ng parol kiritildi.

Natija: SSH login muvaffaqiyatli bo'ldi va tizimga `alice` sifatida kirildi.

12) Local flagni aniqlash

Maqsad: User darajasidagi flagni topish (odatda home papkada yoki maxsus `.txt` faylda bo'ladi) va tizimga kirish darajasi (user-level access)ni tasdiqlash.

Amal:

- `ls`
- `cat local.txt`

Natija: `local.txt` faylidan **alice flag** olindi:

- `cf63f8f7d8f6a4a7157365c30bc86d5b`

Xulosa: `alice` foydalanuvchisi orqali tizimga kirish tasdiqlandi va user-level flag qo'lga kiritildi. Keyingi bosqich: privilege escalation (root huquqini olish) uchun tizim ichida enumeration (sudo huquqlari, SUID, cron, kernel/servislar va h.k.).

Privilege Escalation (Writable filelar → /etc/passwd orqali root)

13) Yozish mumkin bo'lgan fayllarni qidirish

Maqsad: Tizimda qaysi fayllarga yozish (write) ruxsatimiz borligini aniqlash. Noto'g'ri ruxsatlar (misconfiguration) ayniqsa **sistemaviy fayllarda** bo'lsa, bu privilege escalation'ga olib kelishi mumkin.

Amal: Writable fayllar qidirildi (xatolarni yashirish uchun stderr null'ga yo'naltirildi):

- `find / -type f -writable 2>/dev/null`

Natija: writable fayllar ichida kritik topilma aniqlandi:

- `/etc/passwd`

Xulosa: `/etc/passwd` fayliga yozish ruxsati mavjudligi — juda yuqori xavfli holat. Chunki bu faylda foydalanuvchilar haqidagi ma'lumotlar saqlanadi va noto'g'ri sozlangan ruxsatlar orqali yangi user yaratish yoki mavjud user atributlarini o'zgartirish mumkin.

14) /etc/passwd ni tahrirlash orqali yangi (root huquqli) user yaratish

Maqsad: Writable bo'lgan `/etc/passwd` dan foydalanib, tizimga yuqori huquq bilan kirish imkoniyatini olish.

Amal: Fayl tahrirlandi:

- `nano /etc/passwd`

So'ngra root bo'lishning standart usullari tekshirildi:

- `sudo su` → *alice sudoers'da emas*
- `su root` → *root paroli noma'lum*

Keyin `/etc/passwd` ga qo'shilgan yangi user orqali root shell olindi:

- `su john`

Natija: `root@shubuntu` prompt ko'rindi, ya'ni root huquqi qo'lga kiritildi.

15) Root flagni olish

Maqsad: Root huquqi olinganini amaliy tasdiqlash va yakuniy flagni topish.

Amal: root shell ichida flag fayli o'qildi. Ushbu box'da root flag `/home/alice/local.txt` faylida joylashganligi kuzatildi:

- `cat local.txt`

Natija: Root huquqi muvaffaqiyatli qo'lga kiritildi va root flag olindi:

- `cf63f8f7d8f6a4a7157365c30bc86d5b`

16) Xavfsizlik xulosasi (Remediation)

- `/etc/passwd` faylida write ruxsat bo'lmasligi kerak (odatda `644`, owner `root:root`).
- Fayl ruxsatlarini audit qilish: world-writable/system filelarni aniqlash va to'g'rilash.
- Foydalanuvchi yaratish/privilege o'zgarishlarini loglar orqali monitoring qilish.